

Checklist

Physical Security

Physical Access Controls

- ☐ Restrict access to secure and sensitive areas.
- ☐ Use appropriate controls such as locks, PIN pads, RFID/badge readers, biometrics, or security guards.
- ☐ Require more than one security control for highly sensitive areas when appropriate.
- ☐ Ensure employees lock their computer screens when away from their desks.
- ☐ Use computer cable locks where appropriate.
- ☐ Enforce a clear-desk policy.
- ☐ Store sensitive documents in locked cabinets or other secure storage.
- ☐ Restrict access to network jacks, telephone jacks, and other connection points.
- ☐ Disable unused network jacks or require authentication before use.
- ☐ Keep printers, printer trays, and printer discard boxes free of sensitive information.
- ☐ Shred sensitive documents immediately or place them in locked shredding containers.

Video Surveillance

- ☐ Install CCTV cameras at major entrances and exits.
- ☐ Monitor sensitive locations such as server rooms and other high-risk areas.
- ☐ Position cameras so they can clearly capture faces.
- ☐ Position cameras to help correlate badge use with the person using the badge.
- ☐ Protect cameras from tampering.
- ☐ Mount cameras out of easy reach.
- ☐ Use tamper-resistant enclosures where appropriate.
- ☐ Review surveillance footage when investigating suspicious events.
- ☐ Correlate video with badge-access logs and other evidence when possible.

Authentication and Access Maintenance

- ☐ Regularly audit physical authentication controls.
- ☐ Inspect keypads for worn or damaged buttons that could reveal commonly used codes.
- ☐ Replace or repair security controls that expose authentication information.
- ☐ Immediately recover badges, keys, and other access devices from departing employees.
- ☐ Remove former employees' access permissions promptly.
- ☐ Change shared door or alarm codes when authorized personnel leave.
- ☐ Review access permissions whenever an employee changes roles.
- ☐ Avoid relying on shared PINs for highly sensitive areas.

Secure Media

- ☐ Secure USB drives, removable hard drives, CDs, and other portable media.
- ☐ Restrict unauthorized access to sensitive information stored on removable media.
- ☐ Store sensitive media in locked locations when not in use.
- ☐ Secure backup media against loss or theft.
- ☐ Periodically inspect media-storage locations for security problems.
- ☐ Clearly label media according to its data classification.
- ☐ Maintain procedures for distributing media to internal and external users.
- ☐ Use secure couriers when transporting sensitive media.
- ☐ Track the location and status of sensitive media.
- ☐ Require approval before media is removed from secure areas.
- ☐ Maintain records of media movement and transfers.

Datacenter and Equipment Security

- ☐ Use lockable server racks and cabinets.
- ☐ Keep rack keys in a secure, centrally controlled location.
- ☐ Log the checkout and return of rack keys.
- ☐ Prevent unauthorized access through walls, ceilings, or adjoining rooms.
- ☐ Ensure sensitive-room walls extend from floor to ceiling where needed.
- ☐ Evaluate access through suspended ceiling tiles and similar openings.
- ☐ Secure routers, switches, domain controllers, and other equipment in remote offices.

- ☐ Use locked equipment enclosures when a full server rack is impractical.
- ☐ Consider both physical security and fire-safety requirements when designing protected spaces.

Visitors

- ☐ Require all visitors to sign in when entering.
- ☐ Require visitors to sign out when leaving.
- ☐ Record when visitors entered and exited.
- ☐ Record whom each visitor is meeting.
- ☐ Escort visitors to and from controlled areas.
- ☐ Verify a visitor's purpose before allowing access to technology or sensitive areas.
- ☐ Require employee approval before visitors interact with equipment or access information.

Contractors

- ☐ Clearly identify contractors while they are on-site.
- ☐ Require and verify photo identification.
- ☐ Define contractor access permissions in organizational policy.
- ☐ Limit contractor access to areas required for their work.
- ☐ Confirm that contractor vetting or background-check requirements have been completed.
- ☐ Verify contractor requests before granting access to sensitive systems or locations.

Visitor and Contractor Badges

- ☐ Issue badges that clearly distinguish visitors from employees and contractors.
- ☐ Limit visitor badges to the duration of the visit.
- ☐ Require badges to be returned when visitors sign out.
- ☐ Use automatically expiring or self-voiding badges when appropriate.
- ☐ Train employees to recognize legitimate badge types.
- ☐ Remain aware that badges can be copied or counterfeited.
- ☐ Report lost or stolen badges immediately.
- ☐ Disable lost, stolen, or unreturned badges promptly.

Physical Security Training

- ☐ Train employees on physical as well as digital social-engineering risks.
- ☐ Teach employees not to allow unauthorized people into restricted areas.
- ☐ Reinforce that politeness should not override security procedures.
- ☐ Train employees to recognize suspicious behavior involving equipment, doors, badges, and media.
- ☐ Regularly reinforce physical-security expectations with signs, reminders, and awareness training.

Tailgating

- ☐ Require each person to authenticate individually at restricted entrances.
- ☐ Do not hold secure doors open for unknown or unauthorized people.
- ☐ Challenge or report people who enter restricted areas without authenticating.
- ☐ Train employees to recognize tailgating and piggybacking attempts.

Badge Cloning

- ☐ Educate employees that RFID and other access badges may be cloned.
- ☐ Require stronger authentication for highly sensitive areas.
- ☐ Periodically test badge-security controls.
- ☐ Investigate suspicious or duplicated badge activity.
- ☐ Combine badge access with another authentication method where risk warrants it.

Malicious Removable Media

- ☐ Do not connect unknown USB drives or other removable media to company devices.
- ☐ Train employees to recognize malicious-media social-engineering tactics.
- ☐ Treat promotional or unexpectedly received USB devices as untrusted.
- ☐ Be suspicious of removable media intentionally left in public or employee areas.
- ☐ Restrict or disable removable-media ports where practical.
- ☐ Use endpoint controls to manage removable-media access when available.

Restricted Access and Pretexting

- ☐ Verify the identity of repair personnel, delivery staff, vendors, and other service workers.
- ☐ Confirm that requested work is expected and authorized.
- ☐ Verify unusual requests with a manager or responsible department.
- ☐ Do not allow someone into a restricted area solely because they appear knowledgeable or appropriately dressed.
- ☐ Verify unexpected devices before connecting or installing them.
- ☐ Confirm that replacement equipment comes from a trusted source.
- ☐ Be cautious of fake work orders, shipping labels, return instructions, and similar pretexts.

Ongoing Physical Security Management

- ☐ Coordinate physical-security activities between information security, facilities, and other responsible departments.
- ☐ Include physical security in internal assessments and penetration tests.
- ☐ Periodically review physical-security policies and procedures.
- ☐ Identify new physical threats and vulnerabilities.
- ☐ Correct identified security gaps in a timely manner.
- ☐ Apply defense-in-depth instead of relying on a single physical-security control.